Excess Extension Privilege and Data Minimisation in SpoilFree

Divyam Saluja

GitHub: salujadivyam | LinkedIn: salujadivyam

Abstract, SpoilFree requested access to every website and ran its content script on all pages, including web mail and messaging and could read text from editable fields. This report describes these privilege and privacy weaknesses and the reductions made: narrowed host permissions, excluded sensitive sites, skipped editable fields and a rule that only text about tracked titles leaves the browser. No misuse was observed.

Index Terms, least privilege, data minimisation, privacy, host permissions, Chrome extension.

I. INTRODUCTION

An extension acts with the permissions it declares and broad permissions enlarge the damage of any bug and the privacy burden on users [1]. Store policy requires that requested access and data handling be limited to what the feature needs [2].

II. WEAKNESS DESCRIPTION

The manifest declared host permission for all addresses, although the extension needs to contact only the API host and the TVmaze host.

The content script matched all addresses, including web mail, a messaging site and a payment site, where text is private.

Text could be read from editable fields, such as a message being typed.

The developer's error report listed an unrelated chat site as its context, which showed that the script ran on every open tab.

III. IMPLEMENTED MEASURES

Host permissions were reduced to the Hugging Face Space and api.tvmaze.com. Fetches to the API are made from the background worker, so the page never holds the API address. The content-script match list keeps all addresses, which is needed for blurring, but excludes Gmail, Outlook web, WhatsApp Web and PayPal [3]. The scanner skips content-editable elements, inputs, text areas and elements with the textbox role. Text is sent only if it names a tracked title or sits on a page whose title or address names one. The watchlist and progress stay in local storage and are never sent to the API.

IV. VERIFICATION

The manifest was parsed and checked for the new key values. On a fake page the scanner skipped an editable block and processed a normal paragraph. The chat site seen in the error report was not added to the exclusion list and is a suggested next step. A privacy policy page is required by the store and has not been written.

V. CONCLUSION

The measures reduce permissions and the amount of text that leaves the device. Because the script still runs on most sites, sending depends on the title gate, which should be described accurately in the privacy policy.

REFERENCES

[1] Google, "Declare permissions," Chrome for Developers. Accessed: Oct. 28, 2026. [Online]. Available: https://developer.chrome.com/docs/extensions/develop/concepts/declare-permissions

[2] Google, "Chrome Web Store program policies," Chrome for Developers. Accessed: Oct. 28, 2026. [Online]. Available: https://developer.chrome.com/docs/webstore/program-policies/

[3] Google, "Content scripts," Chrome for Developers. Accessed: Oct. 28, 2026. [Online]. Available: https://developer.chrome.com/docs/extensions/develop/concepts/content-scripts